

Narrativa Explicativa

El Sistema GQM + PRAGMATIC aplicado a los Indicadores COSO-Ciber

Por qué medimos lo que medimos —y cómo sabemos que vale la pena medirlo

Kit GQM-PRAGMATIC v2025.1 • Abril 2026

"En ciberseguridad, como en la astronomía antigua, llevamos siglos mirando el cielo y tomando nota de los astros visibles. La cuestión no era observar más, sino decidir qué observar. GQM es el telescopio que apunta en la dirección correcta; PRAGMATIC es el criterio que descarta las estrellas que no importan."

1. El Problema de las Métricas Vanidad en Ciberseguridad

Antes de explicar la solución, conviene describir el problema con la honestidad que merece.

La industria de la ciberseguridad ha producido, con generosidad casi inverosímil, un catálogo de métricas que llenan cuadros de mando, alimentan informes anuales y tranquilizan consejos de administración sin que, en muchos casos, sirvan para evitar un solo incidente. Son las denominadas **métricas vanidad**: números que mejoran con el tiempo por inercia burocrática, que son difíciles de relacionar con una pérdida financiera real y que, cuando cambian, no generan ninguna acción concreta.

Algunos ejemplos clásicos de métricas vanidad en ciberseguridad:

- Número de alertas SIEM procesadas por el SOC (¿y qué hicieron con ellas?)
- Número de parches aplicados en el mes (sin indicar cuántos quedaron pendientes)
- Porcentaje de empleados que completaron la formación de concienciación (sin medir si el comportamiento cambió)
- Número de tickets de seguridad cerrados (incentiva cerrar rápido, no resolver bien)

El **Kit GQM-PRAGMATIC** nace para resolver exactamente este problema: proporcionar un marco riguroso que garantice que cada indicador del programa COSO-Ciber existe porque responde a un objetivo real, y que ese objetivo está correctamente anclado en las necesidades de la organización y en los mandatos del regulador.

2. GQM: La Cadena de Trazabilidad

La metodología GQM (Basili, 1994) impone una disciplina sencilla pero transformadora: **ninguna métrica puede existir sin una pregunta que la justifique, y ninguna pregunta puede existir sin un objetivo que la motive.**

Esta cadena de trazabilidad tiene consecuencias prácticas enormes:

- Si no existe un objetivo claro, la métrica no debería medirse.
- Si la métrica no responde a ninguna pregunta relevante, no debería incluirse en el cuadro de mando.
- Si la pregunta no contribuye al objetivo, está mal formulada.

En el contexto del presente marco, la cadena de trazabilidad va más lejos: los **Objetivos Organizacionales** (nivel 1) se derivan directamente de los **Objetivos Nacionales y Regulatorios** (nivel 0), de modo que cada métrica técnica —por ejemplo, el tiempo mediano de parcheo de vulnerabilidades críticas— puede trazarse en línea directa hasta el Artículo 21(2e) de la Directiva NIS2 y el Eje 1 de la Estrategia Nacional de Ciberseguridad de España 2025–2030.

Esta trazabilidad vertical tiene tres beneficios concretos:

1. Legitimidad regulatoria: El CISO puede demostrar ante el regulador o el auditor que sus métricas responden a mandatos normativos específicos, no a preferencias personales.
2. Credibilidad ante el Consejo: El Consejo comprende por qué se mide lo que se mide: está conectado con la estrategia que ellos mismos aprobaron.
3. Priorización de recursos: Cuando hay que decidir entre dos métricas en competencia por los mismos recursos de implementación, la que tiene trazabilidad regulatoria directa gana.

3. PRAGMATIC: El Filtro de Calidad

Si GQM garantiza que medimos *lo que debe medirse*, PRAGMATIC garantiza que lo medimos *bien*. Los 9 criterios del modelo actúan como filtros sucesivos que una métrica debe superar para merecer un lugar en el cuadro de mando operativo del CISO o en el reporte ejecutivo al Consejo.

La experiencia práctica con el modelo revela patrones sistemáticos:

3.1 El Talón de Aquiles: la Independencia (I)

El criterio que más consistentemente score bajo en el presente análisis es el de **Independencia**. Esto no es sorprendente: en ciberseguridad, quien diseña los controles suele ser quien los implementa y quien mide su eficacia. Es un conflicto de interés estructural que la industria prefiere no nombrar abiertamente.

Las métricas más afectadas por este problema son las relacionadas con el comportamiento del SOC (MTTD, MTTR) y con la gestión de identidades (cobertura MFA, revisión de cuentas privilegiadas). La solución no es descartar estas métricas —siguen siendo Premium en todos los demás criterios— sino complementarlas con validaciones independientes periódicas: auditoría de los registros de tiempos de detección, pruebas de penetración no anunciadas, o revisión de la completitud del inventario de cuentas privilegiadas por parte de Auditoría Interna.

3.2 La Fortaleza: la Relevancia (R)

El criterio que obtiene la puntuación más alta en el conjunto es la **Relevancia**. Esto refleja una característica distintiva del marco COSO-Ciber frente a otros sistemas de métricas de ciberseguridad: todas las métricas del presente catálogo están explícitamente ancladas en objetivos de negocio

reconocibles por el Consejo (continuidad de los servicios, gestión del riesgo financiero, cumplimiento regulatorio).

Esto no es accidental: el marco COSO, en su naturaleza, es un lenguaje de gobierno empresarial, no un lenguaje técnico. Aplicarlo a la ciberseguridad fuerza la traducción del tecnicismo al lenguaje del Consejo, y ese proceso de traducción eleva automáticamente la relevancia de las métricas resultantes.

3.3 La Oportunidad Perdida: la Precisión en Cuantificación Financiera

Las métricas de la familia financiera (M-EST-03, M-ROI-01, M-ROI-03) presentan puntuaciones más moderadas en el criterio de **Precisión** (Accurate). Esto es un reflejo honesto de las limitaciones actuales de la cuantificación financiera del ciberriesgo: los modelos ALE y FAIR producen estimaciones con rangos de incertidumbre amplios, especialmente cuando los datos históricos de pérdidas son escasos o están sesgados por el subregistro de incidentes.

La recomendación metodológica es clara: no presentar el ALE como un número puntual ("el riesgo de ransomware cuesta 2,3 millones de euros al año") sino como un intervalo de confianza ("el riesgo estimado está entre 1,1 y 4,8 millones de euros al año, con un percentil 50 de 2,3 millones"). Esta honestidad sobre la incertidumbre es, paradójicamente, lo que hace que el Consejo confíe más en el número que si se presentara como una cifra exacta.

4. La Arquitectura de los 50 Indicadores: Lógica del Diseño

El catálogo de 50 métricas del Kit GQM-PRAGMATIC está diseñado con una lógica deliberada que merece explicarse:

4.1 Distribución por Componente COSO

La distribución de métricas por componente COSO no es uniforme: el **Componente III (Desempeño)** concentra el mayor número de métricas (30 de 50) porque es donde la ciberseguridad produce la mayor cantidad de datos operativos medibles. Los componentes I (Gobernanza) y II (Estrategia) tienen menos métricas pero de mayor impacto ejecutivo. El Componente V (Reporte) tiene un número modesto de métricas muy accionables.

4.2 Leading vs. Lagging Indicators

El catálogo incluye deliberadamente una combinación de:

- Indicadores rezagados (lagging): Miden lo que ya ocurrió (coste de incidentes, tiempo de detección en incidentes pasados). Son precisos pero reactivos.
- Indicadores adelantados (leading): Anticipan el riesgo antes de que se materialice (cobertura de MFA, % de vulnerabilidades sin parchear). Son menos precisos pero accionables preventivamente.

La proporción recomendada para el cuadro de mando del CISO es 60% leading / 40% lagging. El reporte al Consejo debería mostrar ambos tipos, pero explicitar cuáles son adelantados y cuáles son retrospectivos.

4.3 Los 14 Indicadores de Alerta Temprana (IAT)

Los 14 IATs identificados en el Kit de Encuesta COSO-Ciber anterior tienen una correspondencia directa con las métricas del presente catálogo. Son los indicadores que, cuando presentan puntuación ≤ 2 en la encuesta, activan una respuesta inmediata porque:

4. Tienen puntuación PRAGMATIC ≥ 37 (todos son Premium o bordean el Premium)
5. Son leading indicators con alta capacidad predictiva
6. Su deterioro es estadísticamente correlacionado con mayor probabilidad de incidente material

5. El Marco GQM+PRAGMATIC en el Contexto Regulatorio Español

5.1 La Singularidad del Escenario Español

España presenta un escenario regulatorio particularmente complejo en 2026:

- NIS2 en plena implementación, con el Real Decreto de transposición publicado en 2025 y la supervisión de la CNMC y el CCN-CERT en curso.
- DORA aplicable desde enero 2025 a todo el sector financiero supervisado por el Banco de España y la CNMV.
- ENS (RD 311/2022) con categorías alta y esencial que afectan a administraciones públicas y sus proveedores.
- EU AI Act con los primeros plazos de cumplimiento para sistemas IA de alto riesgo en agosto 2026.

Este mosaico regulatorio significa que una organización española de tamaño mediano puede estar sujeta simultáneamente a NIS2, DORA (si tiene actividad financiera), ENS (si presta servicios a AAPP) y EU AI Act (si usa IA en procesos de alto riesgo). El marco GQM+PRAGMATIC está diseñado para esta realidad: las métricas del catálogo tienen trazabilidad explícita a múltiples marcos regulatorios, y la Matriz de Trazabilidad (Documento d) permite identificar qué métricas cubren qué mandatos.

5.2 El Papel de INCIBE y CCN-CERT

El **INCIBE** (Instituto Nacional de Ciberseguridad) y el **CCN-CERT** son las dos autoridades de referencia para la medición de la ciberseguridad en España. Sus publicaciones —el Balance de Ciberseguridad anual del INCIBE y los Informes de Ciberamenazas y Tendencias del CCN-CERT— proporcionan los benchmarks nacionales que permiten contextualizar las métricas del presente catálogo en el escenario español, complementando los datos europeos de ENISA y globales de IBM, Verizon y FAIR Institute.

6. Instrucciones de Uso del Marco para Distintos Perfiles

Para el CISO

El catálogo de 50 métricas es probablemente más del doble de lo que un CISO puede gestionar con atención operativa continua. La recomendación es:

7. Implementar primero los 14 IATs — Son los de mayor urgencia y mayor puntuación PRAGMATIC.
8. Seleccionar un subconjunto de 10–15 métricas para el cuadro de mando mensual — Priorizar leading indicators y métricas con puntuación PRAGMATIC ≥ 38 .
9. Incluir el conjunto completo en el modelo de madurez anual — La encuesta COSO-Ciber (Kit anterior) es el vehículo para la evaluación comprehensiva.

Para el Consejo de Administración

El Consejo no necesita 50 métricas. Necesita entre 5 y 8 indicadores que, juntos, respondan a tres preguntas:

10. ¿Estamos mejorando o empeorando? → IGM + Tendencia trimestral MTDD
11. ¿Cuánto vale el riesgo que asumimos? → ALE total + Ratio cobertura seguro/ALE
12. ¿Estamos cumpliendo con la regulación? → Estado NIS2/DORA/ENS + IATs críticos

Para el Auditor / Evaluador Externo

El marco GQM+PRAGMATIC proporciona la trazabilidad y la justificación metodológica que el auditor necesita para validar que el sistema de métricas de la organización es fiable, relevante y proporcional. La Ficha PRAGMATIC detallada de cada métrica (ver Documento b) es el artefacto de auditoría recomendado para documentar la justificación de cada indicador.

Para el Investigador Académico

El catálogo de 50 métricas, estructurado según GQM y evaluado según PRAGMATIC, constituye un instrumento de investigación validable y reproducible. La encuesta COSO-Ciber es el instrumento de campo; el presente marco GQM+PRAGMATIC es el fundamento metodológico para publicar en revistas de alto impacto (JISA, Computers & Security, Journal of Risk Research) con rigor suficiente para superar la revisión por pares.

7. Limitaciones y Trabajo Futuro

Con la honestidad que exige el rigor metodológico, conviene identificar las limitaciones conocidas del presente marco:

13.

Las puntuaciones PRAGMATIC son razonadas, no validadas empíricamente. La validación requeriría un estudio Delphi con expertos independientes y una prueba de campo en al menos 50 organizaciones. Este marco presenta puntuaciones basadas en el análisis experto del consorcio, pendientes de validación estadística.

14.

Los benchmarks de referencia tienen diferente robustez. Las referencias IBM (Cost of Data Breach) y ENISA (NIS Investments) son metodológicamente robustas. Algunas referencias sectoriales específicas para España son menos granulares y pueden subestimar o sobreestimar ciertos valores.

15.

La cuantificación financiera del riesgo es inherentemente imprecisa. Los modelos ALE/FAIR producen estimaciones, no certezas. El valor de la cuantificación está en el proceso de reflexión que genera, no en la precisión del número.

16.

Los riesgos emergentes (IA adversarial, PQC) tienen métricas en proceso de maduración. Las métricas M-EMG son las menos consolidadas del catálogo, porque el campo está evolucionando más rápidamente que la capacidad de medición. Se revisarán en la versión v2026.1.

Las puntuaciones PRAGMATIC son razonadas, no validadas empíricamente. La validación requeriría un estudio Delphi con expertos independientes y una prueba de campo en al menos 50 organizaciones. Este marco presenta puntuaciones basadas en el análisis experto del consorcio, pendientes de validación estadística.

Los benchmarks de referencia tienen diferente robustez. Las referencias IBM (Cost of Data Breach) y ENISA (NIS Investments) son metodológicamente robustas. Algunas referencias sectoriales específicas para España son menos granulares y pueden subestimar o sobreestimar ciertos valores.

La cuantificación financiera del riesgo es inherentemente imprecisa. Los modelos ALE/FAIR producen estimaciones, no certezas. El valor de la cuantificación está en el proceso de reflexión que genera, no en la precisión del número.

Los riesgos emergentes (IA adversarial, PQC) tienen métricas en proceso de maduración. Las métricas M-EMG son las menos consolidadas del catálogo, porque el campo está evolucionando más rápidamente que la capacidad de medición. Se revisarán en la versión v2026.1.

Narrativa Explicativa — Kit GQM-PRAGMATIC v2025.1 / Abril 2026

Bases teóricas: Basili (1994) GQM · Brotby & Hinson (2013) PRAGMATIC · COSO ERM 2017 · ISO/IEC 27004:2016 · NIST SP 800-55 Rev.2 (2022)